تقرير اختبارات الأمان — وحدة المصادقة TRUST-AI

المسؤول: عضو الأمن 02 | **النطاق:** استعادة كلمة المرور وأمن الإدخال | **الأدوات:** Python (pytest)

تم كتابة وتنفيذ مجموعة اختبارات أمنية آلية على وحدة المصادقة في **TRUST-AI** للتأكد من حماية مسارات استعادة كلمة المرور، إنشاء الحسابات، ومعالجة المدخلات الخاطئة أو الضارة، وشملت الاختبارات 3 ملفات أساسية بإجمالي 15 حالة اختبار:

1. اختبارات نسيان كلمة المرور ورمز OTP (`test_03_otp_reset.py`)

يغطي هذا الملف شاشات استعادة الحساب (Screens 7, 8, 9) ويتحقق من النقاط التالية:

- **منع كشف الحسابات (`test_forgot_password_gives_the_same_answer_for_any_email`):** التأكد من أن طلب `/auth/forgot-password` يرجع نفس كود الحالة (`202`) ونفس شكل الاستجابة سواء كان الإيميل مسجلاً أو غير موجود (`nobody@trust.local`).
- **التحقق من OTP وعدد المحاولات (`test_wrong_otp_is_rejected_and_shows_attempts_left`):** إرسال كود خطأ (`000000`) إلى `/auth/verify-otp` والتأكد من رفضه بكود `400` مع إرجاع `OTP_INVALID` وعدد المحاولات المتبقية (`attemptsLeft`).
- **الحماية من التخمين (`test_otp_cannot_be_brute_forced`) (Brute-Force):** تجربة 10 أكواد متتالية والتأكد من إيقاف المحاولات أو إبطال الرمز بكود `410` أو `429` .
- **تقييد إعادة الإرسال (`test_resend_too_fast_is_limited`):** طلب إعادة إرسال الكود مباشرة على `/auth/resend-otp` والتأكد من منعه بكود `429` .
- **أمان إعادة تعيين كلمة المرور (`test_weak_password_is_rejected` & `test_fake_reset_token_is_rejected`):** التأكد من رفض أي `resetToken` مزيف على `/auth/reset-password` (أكواد `410` / `401` / `400`)، ورفض كلمات المرور الضعيفة مثل `123` بكود `422` عند توفر `RESET_TOKEN` .

2. اختبارات طلب إنشاء حساب ومنع تصعيد الامتيازات (`test_04_request_account.py`)

يغطي شاشة طلب الحساب (Screen 6) عبر `/auth/request-account` و `/roles/requestable` :

- **قبول الطلب الصحيح (`test_valid_request_is_accepted`):** التأكد من قبول بيانات التسجيل السليمة لدور `Analyst` بكود `202` .
- **منع تصعيد الامتيازات (& `test_cannot_request_security_admin` `test_security_admin_is_not_in_requestable_roles`):** التحقق من عدم إمكانية طلب دور `Security Admin` (يرفض بأكواد `422` / `403` / `400`)، والتأكد من عدم ظهوره أصلاً في قائمة الأدوار المتاحة للطلب.
- **شروط التسجيل وقوة الباسورد (`test_policy_must_be_accepted` & `test_weak_password_is_rejected`):** رفض كلمات المرور الضعيفة (`123`) ورفض الطلب في حال عدم الموافقة على السياسة (`acceptedPolicy=False`) بكود `422` .
- **منع كشف الإيميلات المسجلة (`test_existing_email_looks_the_same_as_a_new_one`):** التأكد من تطابق الاستجابة تماماً عند التسجيل بإيميل موجود مسبقاً مقارنة بإيميل جديد.

3. اختبارات أمن الإدخال ومعالجة الأخطاء (`test_05_errors_and_input.py`)

يختبر جميع مسارات المصادقة (`login` , `forgot-password` , `request-account` , `verify-otp` , `reset-password`) ضد مدخلات غير طبيعية:

- **مقاومة المدخلات الشاذة (`test_odd_input_never_gives_a_server_error`):** تمرير محاولات حقن SQL (`' OR 1'='1'`)، نصوص طويلة جداً (5000 حرف)، أكواد XSS (`<script>`)، اجتياز مسارات (`../../etc/passwd`)، وقيم `None` وأرقام في كل الحقول للتأكد من عدم حدوث أي خطأ سيرفر `500` .
- **منع تسريب تفاصيل الأخطاء (`test_errors_do_not_show_stack_traces`):** إرسال طلبات فارغة `{}` والتأكد من عدم ظهور أي `StackTrace` أو `Traceback` أو `System.` في الرد.
- **التعامل مع صيغ غير JSON (`test_login_with_a_body_that_is_not_json`):** إرسال نص عادي غير منسق إلى `/auth/login` والتأكد من معالجته بدون خطأ خادم داخلي.

> **ملاحظة تشغيل:** جميع الاختبارات تعمل تلقائياً بالكامل، ما عدا اختبار `test_weak_password_is_rejected` في ملف `test_03_otp_reset.py` الذي يحتاج تمرير متغير البيئة `RESET_TOKEN` لتشغيله.